Arquitectura y Seguridad de Nimbus Edge

Whitepaper técnico - Plataforma Nimbus Edge y NimbusOS 4.x

Código: NE-500 **Versión:** 1.5 **Fecha:** 2026-09-30

Público objetivo: Arquitectos de soluciones y responsables de seguridad

Resumen

Nimbus Edge es una plataforma de adquisición de datos industriales compuesta por gateways de borde (GX-200 y GX-200L), un plano de mensajería basado en MQTT y una nube de gestión (Nimbus Cloud). Este documento describe la arquitectura de la plataforma y los controles de seguridad que protegen la identidad de los dispositivos, el firmware, los datos en tránsito y en reposo, y el acceso de los usuarios.

1. Visión general de la arquitectura

La plataforma se organiza en cuatro capas:

- **Dispositivo:** sensores, PLC y medidores conectados por Modbus RTU/TCP o entradas digitales.
- **Borde:** el gateway ejecuta el agente `nimbusd`, que muestrea, normaliza, almacena temporalmente y publica los datos.
- **Plataforma:** el broker MQTT, el servicio de ingesta, la base de datos de series temporales y el servicio de alarmas.
- **Acceso:** la API REST v3, Nimbus Console y los webhooks.

El gateway siempre inicia las conexiones hacia la nube. No es necesario abrir puertos de entrada en el firewall del cliente: solo se requiere salida al puerto TCP **8883** (MQTT sobre TLS) y al puerto **443** (API y descargas de firmware).

2. Flujo de datos de telemetría

1. El agente muestrea las fuentes con la frecuencia `telemetry.sample_interval_ms` (1000 ms por defecto).
2. Las muestras se agrupan en lotes de `telemetry.batch_size` elementos (50 por defecto) y se marcan con la hora del dispositivo en milisegundos.
3. Los lotes se publican por MQTT con calidad de servicio QoS 1, lo que garantiza entrega al menos una vez.
4. El servicio de ingesta deduplica por identificador de lote y almacena los puntos en la base de series temporales.
5. Las reglas de alarma se evalúan sobre el flujo ingresado y generan eventos y webhooks.

Operación sin conexión. Cuando la nube no está disponible, el agente guarda los lotes en un buffer persistente en la eMMC de hasta 256 MB. Al restablecerse la conexión, los datos se envían en orden cronológico. Si el buffer se llena, se aplica la política configurada (`drop_oldest`, `drop_newest` o `block`) y se registra el código NE-E1042.

3. Identidad y aprovisionamiento

Cada dispositivo posee una identidad criptográfica única basada en un certificado X.509 emitido por la autoridad certificadora de Nimbus. La clave privada se genera dentro de un **elemento seguro** y nunca sale del equipo.

El aprovisionamiento usa un token de un solo uso con validez de **72 horas**. Una vez canjeado, el equipo obtiene su certificado y establece una conexión TLS con autenticación mutua (mTLS) con el broker.

Los certificados de dispositivo se rotan automáticamente cada **90 días** (parámetro `security.cert_rotation_days`, configurable entre 30 y 365). Si la rotación falla, el equipo sigue operando hasta el vencimiento y genera una alarma anticipada.

4. Arranque seguro y firmware

NimbusOS 4 implementa una cadena de confianza completa: la ROM verifica el cargador de arranque, el cargador verifica el kernel y el kernel verifica el sistema de archivos raíz mediante **dm-verity**. Cualquier modificación no autorizada impide el arranque de esa partición.

Los paquetes de firmware `.nbfw` se firman con **Ed25519**. El equipo verifica la firma y la suma SHA-256 antes de escribir en la partición inactiva. El esquema A/B permite volver a la versión anterior si la actualización falla, tal como se describe en el documento NE-410.

5. Cifrado

- **En tránsito:** TLS 1.2 como mínimo (`security.tls_min_version`); TLS 1.3 disponible desde NimbusOS 4.2.0. TLS 1.0 y 1.1 no están admitidos.
- **En reposo en el dispositivo:** el buffer de telemetría puede cifrarse con **AES-256-GCM** activando `security.buffer_encryption`. Está desactivado por defecto para reducir el consumo de CPU.
- **En reposo en la nube:** los datos se almacenan cifrados con AES-256 y claves administradas por región.

6. Control de acceso

Nimbus Console y la interfaz web local usan control de acceso basado en roles.

Rol	Permisos
admin	Gestión completa, usuarios y firmware
operator	Comandos, configuración y alarmas
viewer	Solo lectura

La interfaz web local escucha en el puerto **8443** por HTTPS. El acceso SSH está desactivado de fábrica y, cuando se habilita con `security.ssh.enabled`, usa el puerto **2222** y solo admite autenticación por clave pública.

7. Auditoría y retención

Todas las acciones administrativas (inicio de sesión, cambios de configuración, comandos, campañas de firmware) se registran en el log de auditoría de la nube, que se conserva **12 meses**. La telemetría se retiene **13 meses** y los paquetes de diagnóstico **90 días**.

8. Residencia de datos

El cliente elige la región al aprovisionar cada dispositivo: `us-east`, `eu-west` o `sa-east`. Los datos de un dispositivo se almacenan y procesan exclusivamente en la región elegida y no se replican a otras regiones.

9. Modelo de amenazas

Amenaza	Control
Suplantación de dispositivo	mTLS y clave en elemento seguro
Manipulación de firmware	Firma Ed25519 y dm-verity
Intercepción de datos	TLS 1.2 o superior
Acceso no autorizado	RBAC, bloqueo tras 5 intentos
Denegación de servicio	Límites de uso y watchdog

10. Divulgación de vulnerabilidades

Las vulnerabilidades pueden reportarse a `security@nimbus-edge.example.com`. Nimbus acusa recibo en 3 días hábiles y sigue una política de divulgación coordinada con un plazo de **90 días**. Los avisos de seguridad se identifican con el formato NSA-AAAA-NNN; por ejemplo, el aviso NSA-2025-014 se corrigió en la versión 4.0.3.

11. Alineación con estándares

Los controles descritos están alineados con los requisitos de la serie IEC 62443 para componentes industriales y con las prácticas de gestión de seguridad de la información de ISO/IEC 27001. Este documento describe controles de diseño y no constituye una certificación.